

Student Name	Oluwatosin Olajubu
Reg. No	C11/26/CGRCE/17602

Evidence Bundle 1

Security Policy Hierarchy & Statement Categorisation

NexusTech Solutions | GRC102 – Information Security Governance | Week 2

1. Purpose

This bundle establishes a four-level documentation hierarchy for NexusTech and applies it to the eight statements supplied in the laboratory scenario. The hierarchy separates management intent from mandatory technical requirements, recommended practices and repeatable operational steps.

2. Hierarchy Definition

Document type	Purpose	Authority	Nature	Level of detail
Policy	Sets organisational direction, intent, principles and mandatory requirements.	Executive/management approval; highest internal authority.	Mandatory.	High-level; defines what and why.
Standard	Defines specific, measurable mandatory requirements that support policy.	Policy owner / designated governance authority.	Mandatory.	More specific; measurable control or configuration requirements.
Guideline	Provides recommended practices or advice to help users achieve secure outcomes.	Policy owner / security function.	Recommended unless explicitly adopted as mandatory.	Practical guidance; flexible.
Procedure	Defines the repeatable steps used to implement a policy or standard.	Process/system owner under policy authority.	Mandatory when the governing policy/process requires it.	Detailed, sequential and action-oriented.

3. Documentation Hierarchy

Direction flows downward from organisational policy into measurable standards and operational procedures, while guidelines support implementation. Evidence and performance information flow upward for monitoring, review and improvement.



Implementation evidence → monitoring → management review → policy improvement

4. Statement Categorisation

#	Classification	Statement type	Justification
1	Policy	Remote access to corporate resources requires MFA.	It establishes a mandatory organisational requirement without prescribing implementation steps.
2	Procedure	MFA mobile-device configuration steps.	It gives sequential instructions for completing a specific operational task.
3	Guideline	Developers are recommended to use parameterised queries.	It recommends a risk-reducing practice rather than imposing a mandatory requirement.
4	Policy	NexusTech is committed to protecting confidentiality, integrity and availability.	It expresses high-level organisational security intent and principles.
5	Standard	Corporate laptops must use full-disk encryption with approved platform technologies.	It defines a specific, measurable mandatory technical requirement supporting security policy.
6	Guideline	Employees should avoid public, unsecured Wi-Fi when travelling.	It provides recommended user behaviour without prescribing an absolute requirement.
7	Procedure	Suspected breaches must be reported to the Helpdesk using the stated channel.	It defines an immediate operational action and reporting route following an event.
8	Standard	Passwords must meet a defined length and complexity threshold.	It sets measurable mandatory authentication requirements rather than describing process steps.

5. Lifecycle Application

NexusTech should manage each document through a controlled lifecycle: identify business/regulatory drivers → assess risk and requirements → draft → consult stakeholders → review and approve → publish and communicate → implement → monitor compliance and effectiveness → review after defined intervals or trigger events → revise, approve and retire superseded versions. This prevents the former five-year-old “IT Rules” document from becoming a static repository of mixed requirements.

6. Governance Outcome

The framework gives each requirement a clear home, owner, authority level and maintenance path. It also supports evidence generation for an ISMS and control environment without treating ISO/IEC 27001, NIST CSF or SOC 2 as identical frameworks.